

Guía de diseño de la Plataforma LOPDP 360

Diagnóstico · Implementación · Auditoría · Operación asistida del DPD/DPO

Blueprint funcional, normativo y tecnológico para una solución de cumplimiento demostrable en Ecuador

PRINCIPIO DE DISEÑO

La plataforma no “certifica” si garantiza cumplimiento. Convierte obligaciones aplicables en controles, evidencias, responsables, riesgos, acciones y verificaciones trazables. El DPD/DPO continúa siendo una persona natural independiente; la herramienta habilita y documenta su trabajo, pero no lo sustituye. [F02] [F06]

Campo	Definición
Versión	Borrador 1.1
Fecha de validación normativa	11 de septiembre de 2026
Cobertura	Ecuador · LOPDP, RGLOPDP, normativa SPDP y normas conexas priorizadas
Usuario objetivo	Consultores LOPDP, responsables/encargados, DPD/DPO, auditores y alta dirección
Clasificación	Uso interno / diseño de solución SMARTCIDI
Control de versión	v1.1 · Validación de niveles de madurez SPDP; rediseño del diagnóstico para una sesión de máximo 60 minutos; límite técnico de 80 preguntas visibles; bibliografía y fecha de corte actualizadas.

Supuesto sobre el assessment analizado

No se identificó en los archivos un assessment separado con ese nombre. Para esta guía se toma como base el modelo de madurez publicado por la SPDP en su Guía de Protección de Datos desde el Diseño y por Defecto, que utiliza los ejes DevPrivOps, DevSecOps y DevRiskOps y niveles de madurez 0 a 3. Si SMARTCIDI dispone de un assessment propio distinto, debe incorporarse como catálogo versionado adicional, sin reemplazar la trazabilidad normativa. [F05]

Resumen ejecutivo

La solución recomendada no debe construirse como un formulario grande ni como un repositorio documental aislado. Debe ser un sistema de gestión de cumplimiento basado en relaciones trazables entre requisito, aplicabilidad, actividad de tratamiento, control, evidencia, riesgo, responsable, acción, verificación, auditoría y opinión del DPD/DPO. Ese enfoque permite diagnosticar, implementar, demostrar y sostener la conformidad sin confundir madurez con cumplimiento jurídico.

NÚCLEO DEL PRODUCTO — “COMPLIANCE GRAPH”
Fuente normativa → requisito → regla de aplicabilidad → actividad/RAT → control → evidencia → riesgo → acción → responsable → verificación → hallazgo → recomendación DPD/DPO → reporte. Cada elemento debe conservar versión, fecha, fuente, responsable, estado y bitácora.

El modelo oficial de madurez de la SPDP es valioso porque exige evaluar por actividad de tratamiento, justificar la calificación con rationales y apoyarse en el RAT. Sin embargo, para uso empresarial debe ampliarse: la plataforma debe mantener separados el índice de madurez, el estado de conformidad, la cobertura de evidencia y el riesgo residual. Un proceso puede ser “maduro” y aún conservar una brecha jurídica puntual; del mismo modo, una obligación binaria no debe convertirse artificialmente en un porcentaje de cumplimiento. [F05]

La versión 2026 del marco ecuatoriano exige que la arquitectura sea actualizable. Entre otras novedades relevantes, la SPDP mantiene normativa específica sobre transferencias, tratamientos a gran escala e inteligencia artificial; la Ley Orgánica para el Fortalecimiento de la Ciberseguridad modificó el régimen de notificación de vulneraciones. Por ello, la base de conocimiento debe ser viva, con control de versiones y revisión humana antes de activar una regla automática. [F10] [F11] [F12] [F13] [F14]

Decisiones de diseño que no deberían negociarse

- Separación de funciones: el módulo de implementación y el módulo DPD/DPO deben tener permisos, responsables y flujos diferentes. El DPD/DPO asesora y supervisa; no ejecuta directamente la implementación, la gestión de riesgos o las EIPD del responsable. [F06]
- Evidencia antes que autodeclaración: una respuesta “Sí” sin soporte no debe equivaler a cumplimiento verificado.
- Normativa como dato versionado: cada regla debe citar la fuente exacta, artículo o sección, vigencia, fecha de validación y relación con normas anteriores.
- IA con humano en el circuito: el copiloto puede resumir, relacionar y proponer; no debe emitir una conclusión jurídica definitiva ni cerrar controles automáticamente.
- Privacidad por diseño de la propia plataforma: minimizar información cargada, aislar clientes, restringir datos sensibles identificables, cifrar, registrar accesos y definir conservación desde el inicio.
- Multiempresa y multisector: un núcleo común LOPDP más paquetes sectoriales configurables (salud, educación, financiero, seguros, telecom, comercio, RR.HH., videovigilancia, IA, etc.).
- Las herramientas, documentos deben ser analizadas para cada empresa y/o sector de forma particular.
- La herramienta debería permitir ir incorporando nuevas normativas del Ecuador, de otros países e internacionales. Por ejemplo: módulo dedicado a la LOPDP, otro módulo a la normativa de Continuidad de negocio, Ley de ciberseguridad; etc.
- Primero partimos como un PMV con la LOPDP y luego se puede ir incorporando para las otras normativas

1. Marco de referencia y lectura del assessment de madurez

1.1 Qué aporta el modelo SPDP

La Guía de Protección de Datos Personales desde el Diseño y por Defecto de la SPDP presenta un sistema de estimación de madurez recomendado —no obligatorio— para valorar la permeabilidad de los principios de Cero Confianza en tres ejes: DevPrivOps, DevSecOps y DevRiskOps. La referencia exacta es el capítulo 3, “Criterios para estimar la madurez de la permeabilidad de los principios de DevPrivOps, DevSecOps y DevRiskOps”; en particular, el numeral 3.1 y la Tabla 1 (p. 17) para la madurez de cada principio por proceso, y el numeral 3.3.1 y la Tabla 4 (p. 20) para la madurez global de todos los principios respecto de los procesos que involucran tratamiento de datos personales. La calibración exige un RAT granular y rationales cuantitativos o cualitativos. [F05]

Nivel SPDP	Umbral del modelo recomendado SPDP	Lectura exacta para la plataforma
0 · Caótico	0%	El principio no es conocido o no es considerado necesario en el proceso evaluado.

Nivel SPDP	Umbral del modelo recomendado SPDP	Lectura exacta para la plataforma
1 · Implícito	< 25%	El principio es conocido y necesario, pero está implementado en menos del 25% del proceso.
2 · Temprano explícito	25%–75%	El principio es conocido y necesario, con implementación parcial entre el 25% y el 75% del proceso.
3 · Maduro explícito	> 75%	El principio es conocido y necesario, con implementación en más del 75% del proceso.

Regla de interpretación: los porcentajes anteriores no representan el porcentaje de respuestas “Sí” del cuestionario. En el numeral 3.1 se refieren al grado de implementación del principio dentro de un proceso de tratamiento; y en el numeral 3.3.1, a la implementación de los principios en el conjunto de procesos. Por tanto, el motor no debe convertir automáticamente “preguntas afirmativas / preguntas totales” en un nivel SPDP. Las respuestas, la evidencia y los rationales son insumos para que el sistema —con revisión humana— determine el nivel correspondiente. [F05]

Referencia exacta validada: Superintendencia de Protección de Datos Personales, Guía de Protección de Datos Personales desde el Diseño y por Defecto, 21-oct-2025, cap. 3, numeral 3.1, Tabla 1, p. 17; numeral 3.2, pp. 18–19; y numeral 3.3.1, Tabla 4, p. 20. El propio documento aclara que el sistema de estimación de madurez es recomendable y no obligatorio. [F05]

1.2 Fortalezas del assessment

- Obliga a bajar el análisis a actividades reales de tratamiento, evitando evaluar “la empresa” de manera abstracta.
- Integra privacidad, seguridad y riesgo en lugar de tratarlos como documentos independientes.
- Permite repetir la medición y demostrar evolución.
- Exige rationale, lo que reduce calificaciones arbitrarias.
- Es compatible con un sistema automático porque cada principio puede convertirse en una unidad evaluable con evidencia y criterios.
- Permite descubrir brechas y oportunidades de mejora de la empresa

1.3 Límites que la solución debe corregir

Límite	Respuesta de diseño
Madurez ≠ conformidad	Mantener un estado jurídico separado: Conforme / Parcial / No conforme / No verificado / No aplicable.
Porcentaje no prueba eficacia	Añadir evidencia, prueba de operación, fecha y revisor.
Un promedio puede ocultar brechas críticas	Mostrar “bloqueadores” y obligaciones críticas aparte del promedio.
La aplicabilidad cambia por sector, escala y tratamiento	Motor de reglas con preguntas condicionales y razonamiento visible.
La norma cambia	Versionado regulatorio, diff, impacto y revalidación de controles.
El DPD/DPO debe ser independiente	Separación de permisos y prohibición de asignarle tareas de ejecución propias del responsable.

1.4 Modelo ampliado recomendado

La plataforma debe conservar los tres ejes de la guía SPDP como vista estratégica, pero operar con dominios de control más detallados. Los dominios G01–G16 son una taxonomía operativa de SMARTCIDI —no una clasificación oficial de la SPDP— y solo deben activarse cuando exista trazabilidad hacia una obligación, criterio oficial o buena práctica claramente identificada. Esto permite mapear cada pregunta del assessment a una fuente concreta sin perder la visión DevPrivOps/DevSecOps/DevRiskOps.

ID	Dominio de evaluación	Mapa SPDP
G01	Gobierno y responsabilidad proactiva	DevRiskOps

ID	Dominio de evaluación	Mapa SPDP
G02	Inventario de datos, procesos y RAT	DevPrivOps / DevRiskOps
G03	Licitud, bases de legitimación, transparencia y consentimientos	DevPrivOps
G04	Derechos de titulares	DevPrivOps
G05	Categorías especiales, menores y grupos vulnerables	DevPrivOps / DevRiskOps
G06	Gestión de riesgos y EIPD	DevRiskOps
G07	Protección de datos desde el diseño y por defecto	Los tres ejes
G08	Seguridad y resiliencia	DevSecOps / DevRiskOps
G09	Encargados, terceros, contratos y confidencialidad	DevPrivOps / DevSecOps
G10	Transferencias nacionales e internacionales	DevPrivOps / DevRiskOps
G11	Conservación, bloqueo, eliminación, anonimización/seudonimización	DevPrivOps / DevSecOps
G12	Vulneraciones e incidentes	DevSecOps / DevRiskOps
G13	DPD/DPO, independencia y gobierno de supervisión	DevRiskOps
G14	Auditoría, capacitación y mejora continua	DevRiskOps
G15	IA, perfilamiento y decisiones automatizadas	Los tres ejes
G16	Tratamientos a gran escala y obligaciones reforzadas	Los tres ejes

2. Visión de producto: SMARTCIDI LOPDP 360

Nombre de trabajo: SMARTCIDI LOPDP 360. Es una plataforma multiempresa y multisector para gestionar el ciclo completo de protección de datos: diagnosticar, diseñar e implementar controles, administrar evidencia, auditar, supervisar como DPD/DPO y mantener el sistema frente a cambios regulatorios.

Capacidad	Resultado de negocio
Diagnosticar	Saber qué aplica, qué existe, qué falta, qué riesgo tiene y qué debe priorizarse. Generar reportes
Implementar	Convertir brechas en controles, documentos, responsables, tareas y evidencia aprobada. Generar reportes
Verificar	Auditar eficacia, identificar hallazgos, seguir acciones correctivas y conservar trazabilidad.
Supervisar y seguimiento	Dar al DPD/DPO un cockpit independiente para asesorar, revisar, elevar y reportar sin ejecutar obligaciones del responsable. Debe permitir realizar el seguimiento y cumplimiento de los planes de acción Generar reportes, notificaciones (Como un gestor de proyectos con metodologías ágiles)
Actualizar	Detectar cambios regulatorios, evaluar impacto y reconfigurar reglas, plantillas y controles. Generar reportes
Documentar	La herramienta debe permitir gestionar la documentación generada en todo el proceso
Metodología de trabajo	La herramienta debe ser diseñada con un concepto de gestión de proyectos ágiles, colaborativo, trabajo en equipo.

2.1 Arquitectura conceptual por capas

Capa	Contenido
6 · Experiencia	Portales por rol: Consultor, Responsable/Encargado, DPD/DPO, Auditor, Ejecutivo, Área, TI/Seguridad.
5 · Workflows	Diagnóstico, implementación, derechos, incidentes, EIPD, transferencias, auditorías, DPO, capacitación, cambios regulatorios.
4 · Motor de cumplimiento	Reglas de aplicabilidad, scoring, SLA/fechas, controles, CAPA, alertas, generación de reportes.
3 · Conocimiento	Corpus normativo versionado + RAG con citas + relaciones entre artículos, obligaciones, sectores, controles y plantillas.
2 · Datos y evidencia	RAT, riesgos, proveedores, transferencias, documentos, evidencias, auditorías, DPO, bitácora.
1 · Plataforma segura	IAM, MFA, segregación multi-tenant, cifrado, logs, API, backups, continuidad, monitoreo, DLP.
Integración	La herramienta debe permitir integrar con otras herramientas de manera fácil, intuitiva y con herramientas de IA

2.2 Principio operativo

UNA SOLA FUENTE DE VERDAD Un dato se registra una vez y se reutiliza. Por ejemplo, una actividad del RAT alimenta la matriz de riesgos, la evaluación de gran escala, la EIPD, el inventario de encargados, el registro de transferencias, el aviso de privacidad, los controles, la auditoría y el dashboard. Evitar duplicar matrices que luego divergen.

3. Módulo 1 — Diagnóstico de la empresa

Objetivo: obtener, junto con la empresa, una línea base preliminar, trazable y accionable en una sesión de máximo 60 minutos. El diagnóstico inicial no debe convertirse en una auditoría exhaustiva ni en un formulario de 200 preguntas. Debe usar perfilamiento, preguntas núcleo y ramificación por aplicabilidad. La interfaz no mostrará más de 80 preguntas en una sesión; el diseño recomendado trabaja con un máximo operativo de 68 preguntas y una ruta típica menor por efecto de la lógica condicional. Las validaciones profundas, pruebas de eficacia y evidencias pendientes pasan a implementación o auditoría.

ID	Funcionalidad	Qué debe hacer
DIA-01	Ficha organizacional inteligente	Sector, tipo societario/entidad pública, tamaño, sedes, procesos, canales, sistemas, nube, proveedores, países, IA, videovigilancia, biometría, geolocalización.
DIA-02	Motor de alcance y roles	Determina si actúa como responsable, encargado o corresponsable por tratamiento; conserva rationale y revisión humana.
DIA-03	Determinación DPD/DPO	Wizard basado en LOPDP, RGLOPDP, Resolución 2025-0028 y reglas de gran escala 2026. Entrega conclusión provisional, fuentes y puntos a validar. [F02] [F06] [F11]
DIA-04	Inventario guiado	Levantamiento de procesos, titulares, datos, finalidades, bases, sistemas, repositorios, destinatarios, terceros y flujos.
DIA-05	Assessment adaptativo	Preguntas por dominio y tratamiento con lógica condicional. Ruta típica: 45–60 preguntas; máximo operativo recomendado: 68; límite técnico: 80 preguntas visibles por sesión. Omite lo no aplicable y crea tareas de profundización fuera de la entrevista.

ID	Funcionalidad	Qué debe hacer
DIA-06	Evidencia asistida	Solicita evidencia específica, pero permite precargarla o completarla después. Durante la sesión de 60 minutos basta registrar existencia, ubicación y responsable cuando la revisión documental requiera más tiempo.
DIA-07	Scoring multidimensional	Madurez 0–3, conformidad, cobertura de evidencia, riesgo y confianza de evaluación por separado.
DIA-08	Mapa de brechas	Brecha → obligación → impacto → criticidad → control objetivo → responsable sugerido → plazo → evidencia esperada.
DIA-09	Priorización	Quick wins, críticos regulatorios, alto riesgo, dependencias, esfuerzo y fecha objetivo; fórmula visible y editable.
DIA-10	Informe automático	Informe preliminar automático: resumen ejecutivo, alcance, supuestos, hallazgos, madurez, riesgos, brechas, nivel de confianza, plan y anexos con fuentes. No presenta el diagnóstico rápido como auditoría o certificación.
DIA-11	Modo diagnóstico 60 minutos	Cronómetro y agenda sugerida: 5 min alcance/perfil, 40 min núcleo, hasta 10 min preguntas condicionales y 5 min validación de hallazgos. Si una respuesta exige análisis extenso, se marca “pendiente de validación” y se crea una tarea posterior.
DIA-12	Pre-carga y reutilización	Reutiliza datos ya conocidos de la organización, RAT, documentos y diagnósticos previos para no volver a preguntar información disponible; conserva fecha, fuente y responsable de cada dato.

3.1 Diseño del diagnóstico de máximo 60 minutos

Resultado de la validación normativa: ni la LOPDP, ni su Reglamento General, ni la Guía SPDP de madurez fijan un número obligatorio de preguntas para un diagnóstico. La Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales – Versión 2 señala en su Anexo (p. 75; p. 81 del PDF oficial) que los responsables pueden elaborar las preguntas que consideren necesarias para sus escenarios de riesgo o no utilizar un cuestionario de referencia. Por ello, el límite de preguntas es una decisión metodológica de SMARTCIDI, no una obligación legal. [F04]

Como referencia de diseño —no normativa ecuatoriana—, la herramienta europea Digital Maturity Assessment Tool (DMAT) recomienda una sesión guiada uno-a-uno y señala que, en promedio, la evaluación de una pyme puede durar alrededor de una hora. Este benchmark respalda el timebox de 60 minutos, pero no define obligaciones LOPDP. [F17]

Bloque	Preguntas máximas recomendadas	Tiempo objetivo
Perfil y aplicabilidad	8	5 min
Núcleo: 16 dominios SMARTCIDI × hasta 3 preguntas	48	40 min
Condicionales críticas (solo si se activan)	Hasta 12	Hasta 10 min
Validación de hallazgos y próximos pasos	Sin nuevas preguntas	5 min

Diseño recomendado: 68 preguntas como máximo operativo de la ruta completa (8 + 48 + 12), con una ruta típica de aproximadamente 45–60 preguntas gracias al salto de ítems no aplicables. La plataforma debe imponer un límite técnico absoluto de 80 preguntas visibles en el diagnóstico inicial. El banco maestro puede contener más controles y pruebas para implementación y auditoría, pero esos ítems no deben inflar la entrevista inicial. Cada pregunta deberá estar vinculada a fuente, aplicabilidad, evidencia esperada y rationale.

Criterio de cierre de la hora: cualquier asunto que requiera lectura contractual, revisión de configuraciones técnicas, muestreo de evidencias o interpretación jurídica específica se registra como “pendiente de validación”. El reporte debe diferenciar claramente hallazgo confirmado, indicio de brecha y dato no verificado.

3.2 Regla de evidencia para evitar falsos positivos

Nivel	Criterio	Efecto
E0 · Sin evidencia	Autodeclaración o respuesta sin soporte.	No debe marcarse como “verificado”.
E1 · Documentada	Existe borrador o documento, pero no se prueba su uso.	Puede soportar diseño, no eficacia.
E2 · Implementada	Hay documento aprobado y evidencia reciente de operación.	Permite validar implementación.
E3 · Probada	Además existe prueba, muestreo, auditoría o métrica de eficacia.	Mayor nivel de aseguramiento.

Recomendación técnica SMARTCIDI: sin evidencia al menos E1, el motor no debería permitir que una calificación de madurez alcance el nivel 2 o 3 de forma automática. Esta es una regla interna de aseguramiento; no es una escala establecida por la SPDP.

Regla general:

- En el resultado del diagnóstico, toda brecha, recomendación, o incumplimiento dar referencia en detalle con el artículo de la normativa respectiva.

4. Módulo 2 — Implementación de la LOPDP

Objetivo: transformar cada brecha aprobada en un paquete de trabajo con dueño, fecha, control, documento/evidencia y criterio de cierre. La LOPDP exige al responsable implementar medidas administrativas, técnicas, físicas, organizativas y jurídicas, verificar periódicamente su eficacia, gestionar riesgos y aplicar protección desde el diseño y por defecto. [F02]

ID	Funcionalidad	Resultado
IMP-01	Plan de implementación	Backlog por brecha, dependencias, prioridad, esfuerzo, responsable, aprobador, fecha y evidencia.
IMP-02	RAT maestro	Constructor y registro versionado de actividades de tratamiento; importación/exportación; historial de cambios.
IMP-03	Bases de legitimación	Matriz por finalidad y tratamiento; alerta si se usa una base incompatible o sin soporte; módulo específico de interés legítimo. [F09]
IMP-04	Transparencia y consentimientos	Generador controlado de avisos, textos informativos y registros de consentimiento cuando corresponda.
IMP-05	Derechos de titulares	Procedimiento, intake, validación, asignación, seguimiento, respuesta y expediente de evidencia.
IMP-06	Riesgos y EIPD	Contexto → identificación → análisis → evaluación → tratamiento; EIPD cuando proceda; rationale obligatorio. [F04]
IMP-07	Privacy by Design gate	Checklist/risk gate para proyectos nuevos, cambios de sistema, formularios, campañas, IA y automatización. [F05]

ID	Funcionalidad	Resultado
IMP-08	Encargados y terceros	Due diligence, clasificación de rol, contrato, cláusulas, medidas, revisiones y evidencias. [F07]
IMP-09	Transferencias	Registro nacional/internacional, finalidad, base, destinatario, garantía/instrumento, medidas, evidencia y conservación. [F10]
IMP-10	Conservación y disposición	Tabla de retención por dato/tratamiento, reglas de bloqueo, eliminación, anonimización y evidencias. [F08]
IMP-11	Seguridad	Catálogo de controles jurídicos, organizativos, técnicos y físicos; mapeo opcional a ISO/IEC 27002 como buena práctica. [F15]
IMP-12	Incidentes y vulneraciones	Playbook, registro, evaluación de riesgo, reloj, destinatarios, textos y post-mortem; reglas versionadas. [F13]
IMP-13	Gran escala	MTGE, casos directos, obligaciones reforzadas, revisión periódica y evidencia. [F11]
IMP-14	IA y automatización	Inventario de sistemas IA, tratamientos, decisiones automatizadas, riesgos/EIPD, seguridad, auditoría y transparencia. [F12]
IMP-15	Capacitación	Plan por rol, contenidos, asistencia, evaluación, renovaciones y evidencia.
IMP-16	Gestión documental	Plantillas, versionado, workflow de revisión/aprobación, vigencia, propietario, próxima revisión, relaciones con controles.
	Notificaciones	Generar notificaciones a los involucrados y trazabilidad
	Reportería	Generar reportes, estadísticas, indicadores, dashboards

4.1 Generador documental con gobernanza

La herramienta puede generar borradores, pero no debe publicar automáticamente políticas, contratos o respuestas oficiales. Cada documento debe tener: organización, alcance, fuente normativa, versión, propietario, revisor, aprobador, fecha de vigencia, próxima revisión y enlaces a controles/evidencias.

Plantillas mínimas: política de protección de datos, aviso de privacidad, textos para formularios/canales, cláusulas con encargados y personal, confidencialidad, procedimiento de derechos, procedimiento de incidentes, conservación/eliminación, transferencias, EIPD, evaluación de interés legítimo, registro de incidentes, actas de revisión y formatos DPO.

La herramienta debe permitir una gestión documental y su búsqueda mediante metadatos.

5. Módulo 3 — Auditorías LOPDP

Objetivo: evaluar diseño, implementación y eficacia. La Guía de Gestión de Riesgos de la SPDP contempla auditorías permanentes y auditorías jurídicas, organizacionales y técnicas. Además, la Norma 2026-0005 establece, para tratamientos a gran escala, auditorías internas o externas al menos cada doce meses y conservación del informe por un mínimo de cinco años, salvo la equivalencia prevista en la propia norma. [F04] [F11]

ID	Funcionalidad	Resultado
AUD-01	Programa de auditoría	Plan anual, alcance, criterios, procesos, tratamientos, sedes, auditores, independencia y calendario.
AUD-02	Auditoría basada en requisitos	Checklist generado desde el corpus vigente al corte de auditoría; cada ítem cita fuente y versión.
AUD-03	Muestreo de evidencia	Población, muestra, criterio, evidencia revisada, resultado y observaciones.

ID	Funcionalidad	Resultado
AUD-04	Pruebas de eficacia	Pruebas para controles operativos: accesos, backups, derechos, incidentes, eliminación, contratos, revisiones.
AUD-05	Hallazgos	No conformidad/brecha, observación, oportunidad de mejora, evidencia, requisito, impacto y clasificación.
AUD-06	CAPA	Causa, corrección, acción correctiva/preventiva, responsable, vencimiento y evidencia de cierre.
AUD-07	Verificación de cierre	Un rol independiente valida que la acción resolvió la causa y que la evidencia es suficiente.
AUD-08	Reauditoría	Programación automática de follow-up por criticidad y riesgo.
AUD-09	Informe firmado/aprobado	Generación de informe con anexos de evidencia y registro de aprobaciones.
AUD-10	Histórico comparativo	Tendencia de hallazgos, reincidencias, tiempo de cierre, madurez y riesgo por periodo.
	Notificaciones	Generar notificaciones a los involucrados y trazabilidad
	Reportería	Generar reportes, estadísticas, indicadores, dashboards

5.1 Reglas de independencia

- El auditor no debería poder cerrar como “verificado” una acción que él mismo ejecutó.
- El DPD/DPO puede revisar el programa, observar resultados y supervisar el seguimiento, pero no debe transformarse en implementador del control.
- La auditoría debe conservar el snapshot de normativa y preguntas utilizadas; una norma nueva no debe reescribir retrospectivamente el resultado histórico.

6. Módulo 4 — Cockpit del DPD/DPO

RESTRICCIÓN JURÍDICA CENTRAL

La herramienta “apoya las funciones” del DPD/DPO; no puede ser el DPD/DPO. La LOPDP define al delegado como persona natural y su reglamento exige independencia e imparcialidad. Además, el DPD/DPO no debe implementar directamente la LOPDP, ejecutar la gestión de riesgos/EIPD del responsable ni tomar decisiones sobre finalidades o medios. [F02] [F06]

ID	Funcionalidad	Resultado
DPO-01	Bandeja de asesoría	Consultas internas con contexto, fuente, recomendación, destinatario, fecha y seguimiento.
DPO-02	Plan anual DPO	Objetivos, revisiones, auditorías, capacitaciones, reuniones de alta dirección y entregables.
DPO-03	Supervisión de cumplimiento	Vista de brechas, RAT, riesgos, EIPD, medidas, contratos, transferencias e incidentes sin ser dueño ejecutor.

DPO-04	Opiniones y recomendaciones	Dictamen técnico-consultivo interno, no vinculante, versionado y con constancia de recepción/decisión del responsable.
DPO-05	Derechos de titulares	Supervisión del expediente y alertas; el área responsable ejecuta la atención. [F06]
DPO-06	Riesgos y EIPD	Revisión, observaciones y seguimiento; no ejecución directa. [F06]
DPO-07	Vulneraciones	Asesoría y supervisión de evaluación/notificaciones; la decisión y ejecución permanecen en el responsable.
DPO-08	Punto de contacto SPDP	Registro de comunicaciones, requerimientos, respuestas, reuniones y evidencia.
DPO-09	Independencia	Registro de acceso al máximo nivel, recursos, recomendaciones, conflictos de interés y evaluación institucional anual. [F06]
DPO-10	Informe a alta dirección	Dashboard y reporte periódico: cumplimiento, riesgos, derechos, incidentes, auditorías, acciones, cambios regulatorios.
DPO-11	Bitácora de diligencia	Evidencia cronológica de asesorías, advertencias, seguimientos, escalaciones y respuestas recibidas.
DPO-12	Multi-cliente seguro	Para DPO externo: portafolio de clientes con aislamiento de datos, agenda, reportes y SLA, sin mezcla documental.

6.1 Separación de permisos DPO vs. implementador

Acción	Implementador / Responsable	DPD/DPO
Crear acción de implementación	Sí	No; puede recomendar
Ser propietario de control	Sí	No
Ejecutar EIPD/riesgo por el responsable	Sí, rol responsable designado	No; asesora/revisa
Emitir recomendación DPO	No como DPO	Sí
Cerrar hallazgo operativo	Sí, con verificación	No si implica ejecutar el control
Escalar a alta dirección	Sí	Sí, función central
Acceder a evidencia necesaria	Según necesidad	Sí, en alcance de supervisión
Modificar finalidad/medios del tratamiento	Responsable autorizado	No

7. Base de conocimiento normativa y “Regulation as Code”

La base de conocimiento es el componente que más diferencia una herramienta de cumplimiento de un gestor de tareas. Debe almacenar la fuente primaria, pero también traducirla a unidades operativas versionadas. La lista de resoluciones de la SPDP consultada el 11-sep-2026 incluye normativa 2025 y 2026 relevante sobre riesgos/EIPD, contratos, DPD/DPO, anonimización, interés legítimo, transferencias, gran escala e IA. [F14]

Metadato	Uso
Autoridad / emisor	SPDP, Asamblea Nacional, Presidencia/Registro Oficial u otra autoridad competente.
Tipo y número	Ley, reglamento, resolución, guía, modelo, circular, consulta.
Título oficial	Texto exacto.
Publicación / vigencia	Fechas separadas; estado y notas de transición.
Unidad jurídica	Artículo, numeral, anexo, sección o criterio.

Metadato	Uso
Tema / sector	Derechos, DPO, riesgo, salud, IA, transferencias, etc.
Fuerza / naturaleza	Obligación legal, normativa secundaria, guía oficial, criterio no vinculante, buena práctica.
Relaciones	Reforma, reemplaza, complementa, desarrolla, referencia, posible conflicto.
Regla operativa	Condición, obligación, evidencia esperada, responsable, periodicidad/plazo.
Trazabilidad	URL oficial, hash, versión del archivo, fecha de validación y revisor.

NOTA:

La herramienta solo consultará información que tiene almacenada como base de conocimiento y debe ir actualizándose de forma continua con la normativa que genera el organismo de regulación y control respectivo

7.1 Jerarquía de confianza del corpus

Nivel	Fuente	Ejemplos	Regla de uso
A	Fuente oficial primaria	Registro Oficial, SPDP, Asamblea, Presidencia/gob.ec según corresponda.	Puede activar reglas tras validación humana.
B	Guía/modelo oficial	Guías SPDP, modelos metodológicos.	Orienta; identificar expresamente si es recomendación.
C	Consulta absuelta	Respuesta pública SPDP.	Contexto interpretativo; no asumir carácter vinculante si la propia respuesta indica lo contrario.
D	Estándar / buena práctica	ISO/IEC 27002, marcos técnicos.	No convertir en obligación legal salvo adopción contractual/regulatoria específica.
E	Fuente secundaria	Blog, artículo doctrinal, notas.	Solo apoyo; nunca fuente única de una obligación.

7.2 Flujo de actualización regulatoria

Paso	Etapas	Control
1	Detectar	Crawler/monitor solo en fuentes oficiales autorizadas.
2	Capturar	Guardar documento, metadata, hash y fecha.
3	Comparar	Diff contra la versión anterior y clasificar cambios.
4	Validar	Revisor humano confirma vigencia, jerarquía, entrada en vigor y efecto.
5	Mapear impacto	Identificar preguntas, controles, plantillas, workflows, SLA y clientes afectados.
6	Probar	Ejecutar pruebas de regresión de reglas y reportes.
7	Publicar	Activar nueva versión sin borrar la anterior.
8	Notificar	Alertar a consultores/DPD/DPO y crear tareas de revalidación donde aplique.

7.3 Ejemplo de regla explicable: obligación de DPD/DPO

La salida nunca debe ser solo “Sí/No”. Debe mostrar qué hechos se ingresaron, qué regla se activó, la fuente y los puntos pendientes. Ejemplo de lógica conceptual: sector público → verificar obligación; actividades incluidas en supuestos especiales del Reglamento DPO → verificar; tratamiento a gran escala → aplicar casos directos o MTGE cuando corresponda; si el MTGE alcanza el umbral normativo, se activan las consecuencias previstas, incluida la designación obligatoria del DPD/DPO. [F06] [F11]

FORMATO DE SALIDA

Resultado: “DPD/DPO obligatorio — sujeto a validación del responsable”. Motivo: tratamiento X fue clasificado como gran escala. Fuente: Resolución SPDP-SPD-2026-0005-R, Art. 12.2 / Art. 14 según el caso. Evidencia: ficha de tratamiento + cálculo + fecha + revisor. Nunca ocultar el razonamiento de aplicabilidad.

8. Copiloto IA para consultas, análisis y generación

La IA debe funcionar sobre recuperación aumentada (RAG) y no sobre memoria general como fuente jurídica. Cada respuesta normativa debe provenir del corpus autorizado, citar la unidad exacta y señalar la fecha/versión. La Norma General 2026 sobre IA exige, cuando los sistemas de IA tratan datos personales, transparencia, gestión de riesgos/EIPD, medidas de seguridad, registro en el RAT y auditoría según riesgo. [F12]

Capacidad IA	Control obligatorio
Consulta normativa	Pregunta en lenguaje natural → respuesta con cita, versión, vigencia y nivel de confianza.
Consulta de cliente	Pregunta sobre sus propios documentos → respuesta limitada a su tenant y permisos.
Gap assistant	Compara evidencia con requisito y propone hallazgo; requiere aprobación humana.
Document drafting	Genera borradores desde plantillas aprobadas y datos estructurados; marca [POR VALIDAR].
Risk assistant	Sugiere escenarios/controles y ayuda a redactar rationale; no fija riesgo final por sí solo.
DPO assistant	Prepara minutas, recomendaciones, reportes y preguntas de revisión, sin ejecutar obligaciones.
Audit assistant	Sugiere pruebas y resume evidencias; no cierra hallazgos automáticamente.
Regulatory diff	Resume cambios entre versiones y propone objetos impactados.

8.1 Guardrails de IA

- Política “sin fuente, no hay respuesta normativa concluyente”.
- No usar información de clientes para entrenar modelos generales por defecto.
- Aislamiento de embeddings/índices por tenant y filtros de autorización antes de recuperar documentos.
- Redacción/anonimización preventiva de contenido sensible; bloquear carga de historias clínicas, cédulas u otros datos identificables innecesarios.
- Guardar prompt, fuentes recuperadas, respuesta, modelo/versión, usuario, fecha y aprobación para auditoría, con límites de retención.
- Indicador visible: “Fuente normativa”, “Guía oficial”, “Buena práctica” o “Criterio SMARTCIDI”.
- Las decisiones de aplicabilidad, cierre de controles, notificación de incidentes y firma de documentos requieren intervención humana autorizada.
- Siempre validar y verificar la información

9. Motor de riesgos, EIPD y gran escala

El motor debe seguir la lógica de gestión de riesgos promovida por la SPDP: establecer contexto, identificar riesgos, analizar, evaluar y tratar; los escenarios deben centrarse en posibles afectaciones a derechos y libertades. La EIPD no debe convertirse en un checklist aislado. [F04]

Objeto	Campos mínimos
Contexto	Tratamiento, finalidad, interesados, categorías de datos, sistemas, terceros, geografía, volumen, frecuencia.
Escenario de riesgo	Activo/actividad + amenaza/evento + vulnerabilidad + consecuencia sobre derechos/libertades.
Riesgo inherente	Probabilidad/frecuencia e impacto antes de controles adicionales.
Controles	Jurídicos, organizativos, técnicos y físicos; responsable, eficacia y evidencia.
Riesgo residual	Nivel después de controles; aceptación/escalamiento documentado.
Rationale	Justificación cuantitativa/cualitativa de criterios, métricas y decisiones.
EIPD	Expediente conectado al tratamiento, riesgos, medidas, opiniones DPO y aprobaciones.

9.1 Motor MTGE / tratamientos a gran escala

La Resolución SPDP-SPD-2026-0005-R dispone que el cálculo MTGE produce efectos jurídicos cuando alcanza el umbral establecido y contempla además casos de calificación directa. Entre sus efectos figuran la EIPD previa, DPD/DPO obligatorio, incorporación en el RAT y medidas reforzadas; también exige revisión de variables y reglas específicas de auditoría para gran escala. [F11]

Elemento	Diseño
Variables	Número de titulares, volumen, categorías de datos, frecuencia, permanencia y alcance geográfico, según la norma vigente.
Casos directos	Catálogo normativo versionado: salud en los términos de la resolución, ciertos perfilamientos, vigilancia sistemática, biometría/geolocalización, etc.
Salida	Puntaje/regla aplicada + clasificación + obligaciones activadas + evidencia + fecha de recálculo.
Control	No sumar tratamientos distintos para forzar un resultado; evaluar cada tratamiento conforme a la regla y consultas oficiales aplicables.
Revisión	Automática al cambiar variables y recordatorio periódico; el responsable valida.

10. Gestión de derechos, incidentes y transferencias

10.1 Derechos de titulares

Etapas	Función
Recepción	Canal, fecha/hora, derecho invocado, responsable interno, expediente.
Verificación	Identidad mediante método proporcional; evitar recolectar más datos de los necesarios.
Análisis	Localizar tratamientos, sistemas, terceros y excepciones aplicables.
Ejecución	Tareas al área responsable; el DPO supervisa si corresponde.

Etapa	Función
Respuesta	Plantilla controlada, revisión/aprobación y constancia de entrega.
Cierre	Evidencia, lecciones, métrica de tiempo y eventual acción correctiva.

10.2 Vulneraciones e incidentes

El playbook debe usar reglas versionadas, porque el artículo 43 de la LOPDP fue modificado por la Ley Orgánica para el Fortalecimiento de la Ciberseguridad publicada el 22-may-2026. El diseño debe incluir cronómetro, matriz de destinatarios, evaluación del riesgo para derechos/libertades, motivos de demora, evidencias y comunicaciones al titular cuando proceda. [F13]

ID	Componente	Diseño
INC-01	Triage	Tipo de vulneración: confidencialidad, integridad, disponibilidad; datos, titulares, origen, alcance.
INC-02	Reloj normativo	Fecha/hora de constancia, hitos de decisión y alertas configuradas con la norma vigente.
INC-03	Destinatarios	SPDP, regulador/control competente, CSIRT y titulares según aplicabilidad; no enviar automáticamente sin aprobación.
INC-04	DPO	Notificación interna inmediata al DPO para asesoría/supervisión; registro de observaciones.
INC-05	Evidencia	Cronología, decisiones, contención, análisis forense disponible, notificaciones, medidas y post-mortem.

10.3 Transferencias nacionales e internacionales

La Norma General 2026 sobre transferencias exige, entre otros elementos, documentar legalidad/legitimidad y conservar documentación de soporte durante al menos tres años; para transferencias nacionales exige finalidad lícita/legítima/determinada, base de legitimación y consentimiento informado salvo excepciones legales, además de medidas de protección. [F10]

Bloque	Campos
Inventario	Origen, destinatario, país, rol, datos, titulares, finalidad, frecuencia, sistema/canal.
Calificación	Transferencia, comunicación, encargo u otro flujo; resultado revisado por profesional cuando exista duda.
Base / instrumento	Base legitimadora y mecanismo/garantía aplicable, enlazado a contrato y evaluación.
Medidas	Minimización, canal seguro, cifrado u otras medidas, onward transfers y controles.
Evidencia	Contrato, evaluación, medida, aprobación, vigencia, conservación y requerimientos de SPDP.

11. Documentación y repositorio de evidencia

El repositorio debe ser orientado a evidencia, no a carpetas. Cada archivo o registro debe relacionarse con requisitos y controles. El sistema puede integrarse con SharePoint, Google Drive u otros DMS, pero debe conservar metadatos y enlaces de trazabilidad aun si el archivo reside fuera de la plataforma.

Metadato	Criterio
ID único	EVD-AAAA-NNNN
Tenant / organización	Aislamiento obligatorio.
Control / requisito	Uno o varios enlaces.
Tipo	Política, contrato, captura, log, acta, reporte, registro, prueba.
Propietario / custodio	Rol responsable.
Versión / hash	Integridad y cambio.
Fecha / vigencia	Creación, aprobación, próxima revisión, vencimiento.
Clasificación	Pública / interna / confidencial / datos personales / categoría especial.
Retención	Regla y evento de disposición.
Revisión	Quién verificó, qué concluyó y cuándo.

11.1 Controles para carga de información

- Aviso preventivo: no subir bases reales de clientes, pacientes, empleados u otros titulares si no son necesarias para demostrar el control.
- Detector DLP/PII que advierta sobre cédulas, teléfonos, correos, historias clínicas, imágenes médicas y otros datos sensibles; permitir redactar antes de guardar.
- Antimalware y sandbox de archivos.
- Control de permisos por documento y por expediente.
- Retención y borrado por política; bloqueo legal cuando proceda.
- Descarga y compartición con marca de auditoría y, para información crítica, autorización adicional.

12. Dashboard, métricas y reportes

El dashboard debe evitar el mensaje engañoso “Cumplimiento = 87%”. La dirección necesita una vista balanceada que separe cobertura normativa, madurez, evidencia, riesgo y ejecución del plan.

Métrica	Definición	Vista
Cobertura de requisitos aplicables	Requisitos evaluados con estado / requisitos aplicables.	Conformidad
Conformidad verificada	Requisitos conformes con evidencia válida / aplicables.	Conformidad
Madurez global y por eje	Promedio normalizado de niveles 0–3 sobre el espacio aplicable.	Madurez SPDP
Cobertura de evidencia	Controles con evidencia vigente / controles aplicables.	Aseguramiento
Brechas críticas abiertas	Conteo y tendencia.	Riesgo / gestión
Riesgo residual alto	Tratamientos con riesgo residual por encima del criterio de tolerancia.	Riesgo
Acciones vencidas	Acciones vencidas / abiertas; días promedio vencidos.	Ejecución
Tiempo medio de cierre	Promedio por criticidad y área.	Ejecución
RAT actualizado	% de tratamientos revisados dentro de periodicidad definida.	Gobierno
EIPD pendientes	Tratamientos que requieren EIPD y no tienen una aprobada/vigente.	Riesgo
DPD/DPO	Recomendaciones abiertas, aceptadas, rechazadas con rationale, vencidas.	Supervisión

Métrica	Definición	Vista
Derechos	Solicitudes abiertas, plazo restante, tiempo de respuesta, reincidencias.	Titulares
Incidentes	Incidentes por tipo, severidad, tiempo de detección/contención/notificación.	Seguridad
Terceros	Encargados críticos sin evaluación/contrato/evidencia vigente.	Terceros
Auditoría	Hallazgos abiertos, reincidentes, edad, cierre eficaz.	Aseguramiento
Regulación	Cambios normativos pendientes de análisis e impacto.	Actualización

12.1 Reportes automáticos

Reporte	Audiencia	Contenido
Diagnóstico ejecutivo	Gerencia	Madurez, brechas, riesgos, quick wins y hoja de ruta.
Informe técnico de brechas	Consultor	Detalle requisito-control-evidencia-riesgo-acción.
RAT / inventario	Responsable / DPO	Actividades y metadatos exigibles/configurados.
Plan de implementación	Responsables	Acciones, fechas, bloqueos, evidencias.
Riesgos / EIPD	Responsable + DPO	Escenarios, controles, residual, opiniones y decisiones.
DPO periódico	Alta dirección	Supervisión, recomendaciones, incidentes, derechos, auditorías y cambios.
Auditoría	Gerencia / auditor	Criterios, pruebas, hallazgos, CAPA, conclusiones.
Incidente	Equipo autorizado	Cronología, impacto, decisiones, comunicaciones y post-mortem.
Cambio normativo	Consultor / DPO	Qué cambió, qué objetos afecta, tareas y fecha de revalidación.

13. Automatizaciones y notificaciones

Dominio	Eventos de notificación
Acciones	Por vencer, vencidas, bloqueadas, escaladas.
Evidencias	Próxima revisión, expiración, documento reemplazado, evidencia insuficiente.
RAT	Revisión periódica, cambio en proceso/sistema/proveedor, variable MTGE modificada.
EIPD / riesgos	Riesgo alto, control vencido, cambio significativo, reevaluación.
DPO	Nueva consulta, recomendación sin respuesta, conflicto de interés, reunión con alta dirección, evaluación institucional anual.
Derechos	Recepción, asignación, hitos de plazo, escalamiento, cierre.
Incidentes	Reloj crítico, hitos de decisión y destinatarios; alertas multicanal.
Auditorías	Plan, preparación, evidencia faltante, hallazgo vencido, reauditoría.
Capacitación	Inducción, renovación, prueba pendiente, rol nuevo.

Dominio	Eventos de notificación
Regulación	Nueva publicación oficial, validación requerida, impacto aprobado, controles afectados.

Las notificaciones normativas sensibles no deben ser “fire and forget”. El sistema alerta, prepara y registra, pero la comunicación externa a autoridad/titular requiere aprobación de los roles autorizados y conserva la decisión.

14. Modelo de datos mínimo

Entidad	Función
Organización / tenant	Empresa, entidad, sedes, sector, configuración, responsables.
Usuario / rol / permiso	IAM, pertenencia, función, segregación.
Fuente normativa	Documento, versión, artículo, estatus, hash, URL.
Requisito	Obligación/recomendación, aplicabilidad, evidencia esperada.
Proceso / actividad de tratamiento	Base del RAT y flujos.
Dato / titular / finalidad / base	Metadatos de tratamiento.
Sistema / repositorio / activo	Ubicación lógica/física y controles.
Tercero / encargado / corresponsable	Rol, contrato, due diligence.
Transferencia	Origen/destino/instrumento/medidas.
Control	Diseño, propietario, periodicidad, prueba.
Evidencia	Archivo/registro, versión, hash, vigencia.
Riesgo / EIPD / MTGE	Escenarios, cálculo, rationale, medidas.
Assessment	Pregunta, respuesta, score, evidencia, revisor.
Brecha / hallazgo / acción	CAPA y seguimiento.
Derecho	Solicitud, hitos, respuesta, evidencia.
Incidente	Cronología, riesgo, notificaciones, post-mortem.
DPO opinión / asesoría	Recomendación, estado, respuesta del responsable.
Auditoría	Programa, prueba, hallazgo, informe.
Documento / plantilla	Versión, aprobación, relación normativa.
Métrica / snapshot	Valor, fecha, fórmula, fuente.

14.1 Relación clave

REGLA DE MODELO

Ninguna “brecha” debería existir sin enlazar a un requisito o criterio; ningún requisito marcado “conforme” debería existir sin evidencia suficiente o un rationale explícito de verificación. Esa regla mejora la responsabilidad proactiva y hace reproducible el diagnóstico.

15. Roles, gobierno y segregación de funciones

Rol	Responsabilidad
Administrador plataforma	Configura tenants, integraciones y seguridad; no evalúa contenido por defecto.
Líder SMARTCIDI	Administra metodología, plantillas y catálogos; aprueba releases metodológicos.

Rol	Responsabilidad
Consultor implementador	Diagnostica, propone, configura, guía implementación y valida evidencia en alcance.
Responsable/Encargado	Toma decisiones, asigna propietarios, aprueba controles/documentos y acepta riesgos.
Propietario de proceso	Ejecuta acciones y mantiene evidencias.
Legal	Revisa interpretación, bases, contratos y comunicaciones jurídicas cuando corresponda.
TI/Seguridad	Implementa controles técnicos y aporta evidencia.
DPD/DPO	Asesora, supervisa, coopera con SPDP y reporta de manera independiente.
Auditor	Evalúa contra criterios definidos; no implementa lo que audita.
Alta dirección	Recibe reportes, decisiones críticas, recursos y escalaciones.
Solo lectura	Consulta autorizada sin alterar registros.

15.1 Controles específicos de independencia del DPD/DPO

- Acceso directo y canal reservado con el máximo nivel ejecutivo.
- No permitir asignarle el rol de propietario de tratamiento, control operativo, oficial de seguridad o implementador dentro del mismo tenant cuando genere conflicto.
- Registro de conflicto real, potencial o aparente antes de aceptar funciones y durante la relación.
- Bitácora de recomendaciones y de decisiones del responsable, sin posibilidad de borrado unilateral por el área supervisada.
- Evaluación institucional anual de condiciones de independencia con evidencia de recursos, acceso y tratamiento de recomendaciones, conforme a la normativa aplicable. [F06]

16. Seguridad y privacidad de la propia plataforma

La herramienta será un sistema que trata información sobre organizaciones, usuarios, evidencias y potencialmente datos personales. Por tanto, debe diseñarse como un producto de alto aseguramiento desde el inicio. La arquitectura concreta debe someterse a análisis de roles (responsable/encargado), riesgos, contratos, transferencias y EIPD cuando corresponda.

Control	Diseño mínimo
Aislamiento multi-tenant	Separación lógica fuerte; pruebas automáticas contra acceso cruzado.
IAM	MFA, SSO, RBAC/ABAC, mínimo privilegio, recertificación periódica.
Cifrado	En tránsito y reposo; gestión centralizada de claves; rotación.
Logs	Accesos, cambios, exportaciones, aprobaciones y acciones privilegiadas; integridad y retención definida.
Backups / continuidad	Backups cifrados, pruebas de restauración, RTO/RPO definidos según riesgo.
DLP / clasificación	Clasificación de evidencia, advertencias y bloqueo de cargas de alto riesgo.
Secure SDLC	Threat modeling, revisión de código, SAST/DAST/SCA, gestión de secretos, vulnerabilidades y cambios.
API	OAuth2/OIDC, scopes, rate limit, auditoría, contratos de integración.
Proveedores	Due diligence, contrato, subencargados, seguridad, localización y terminación.
Eliminación	Borrado lógico/físico verificable, retención configurable y evidencia de disposición.
Continuidad regulatoria	Snapshot de reglas y capacidad de rollback metodológico.

ISO/IEC 27002:2022 puede utilizarse para enriquecer el catálogo de controles de seguridad y privacidad. Debe etiquetarse como estándar/buena práctica y no presentarse como obligación general de la LOPDP salvo que una norma, contrato o contexto específico la haga exigible. [F15]

17. Integraciones recomendadas

Categoría	Opciones	Uso
Identidad	Microsoft Entra ID / Google Workspace / SAML-OIDC	SSO, MFA, grupos, bajas.
DMS	SharePoint / Google Drive / repositorio propio	Documentos y evidencia con metadatos.
Correo/calendario	Microsoft 365 / Gmail / Calendar	Alertas, reuniones, vencimientos.
BI	Power BI / dashboards nativos	Indicadores ejecutivos y tendencias.
CRM/ERP	APIs	Descubrir procesos/terceros y sincronizar solo metadata necesaria.
Ticketing	Jira / ServiceNow / Planner / similar	Acciones y hallazgos, manteniendo ID maestro en LOPDP 360.
Seguridad	SIEM / EDR / IAM / backup	Métricas y evidencia de controles; no ingerir datos innecesarios.
Firma	Proveedor de firma autorizado/adequado	Aprobaciones, contratos, constancias.
SPDP / fuentes oficiales	Crawler controlado	Normativa, guías, modelos, consultas y novedades.

Toda integración debe pasar por un registro de terceros, análisis de rol, minimización, seguridad, retención y, cuando corresponda, análisis de transferencias. No se recomienda conectar fuentes de producción con datos sensibles para “demostrar cumplimiento” si basta con metadatos, reportes o muestras anonimizadas.

18. Alternativas de arquitectura tecnológica

Opción	Stack conceptual	Ventaja	Riesgo/consideración
A · MVP Microsoft 365 / Azure	Power Apps/Dataverse o app web; SharePoint; Power Automate; Power BI; Azure OpenAI/RAG privado.	Velocidad de salida, integraciones conocidas, menor desarrollo inicial.	Dependencia de licencias; revisar multi-tenant externo, costos, contratos, residencia/transferencias y escalabilidad.
B · SaaS propio multi-tenant	Frontend web + API + PostgreSQL + object storage + vector store + workflow engine + BI nativo.	Control de producto, comercialización, escalabilidad y UX a medida.	Mayor inversión DevSecOps, soporte, seguridad, continuidad y gobierno de releases.
C · Híbrida	Core SaaS + conectores M365/Google + almacenamiento configurable.	Balance entre producto y ecosistema del cliente.	Mayor complejidad de integración y soporte.

18.1 Recomendación de producto

Para validar metodología y experiencia de usuario, conviene empezar con un MVP modular y API-first. Si SMARTCIDI pretende convertirlo en un producto comercial multi-cliente, la arquitectura objetivo debería ser SaaS propio o híbrida; un prototipo Power Platform puede acelerar descubrimiento, pero no debe definir la arquitectura definitiva sin evaluar costos, segregación de clientes, evidencia, IA y requisitos de seguridad.

19. Roadmap de desarrollo

Fase	Estimación ilustrativa	Salida
Fase 0 · Diseño	3–5 semanas	Modelo normativo, dominios, casos de uso, data model, roles, prototipo UX, reglas DPO/gran escala, backlog y arquitectura.

Fase	Estimación ilustrativa	Salida
Fase 1 · MVP	10–14 semanas	Multiempresa, usuarios/roles, corpus versionado, assessment, acciones, evidencia, RAT, dashboard, reportes, DPO cockpit básico.
Fase 2 · Implementación avanzada	8–12 semanas	Riesgos/EIPD, interés legítimo, transferencias, terceros/contratos, conservación, incidentes, derechos, generador documental.
Fase 3 · Assurance	8–10 semanas	Auditoría, CAPA, pruebas de control, gran escala, métricas avanzadas, DPO anual, trazabilidad reforzada.
Fase 4 · IA e integraciones	8–12 semanas	RAG con citas, regulatory diff, conectores, automatizaciones, analítica multi-cliente y paquetes sectoriales.

Las duraciones son estimaciones de diseño para planificación, no compromisos. Deben recalibrarse según equipo, stack, integraciones, requisitos de seguridad, QA y alcance comercial.

19.1 MVP: criterio de “hecho”

Área	Criterio
Normativa	Toda regla del MVP tiene fuente, unidad, versión, fecha de validación y revisor.
Diagnóstico	Produce resultados reproducibles desde respuestas + evidencia + aplicabilidad.
Implementación	Cada brecha puede convertirse en acción y cerrarse solo con evidencia/verificación.
DPO	Permisos impiden asignar al DPO responsabilidades operativas incompatibles.
Auditoría básica	Snapshot de criterios y exportación de evidencia.
Seguridad	MFA, mínimo privilegio, logs, backups probados, segregación tenant y pruebas de acceso.
IA	Si se incluye en MVP: respuestas jurídicas con citas, sin aprendizaje con datos del cliente y con aprobación humana.

20. Requisitos funcionales priorizados

ID	Requisito	Prioridad
FR-001	Crear y aislar organizaciones/tenants	Must
FR-002	Administrar usuarios, roles y permisos	Must
FR-003	Configurar sectores, sedes y procesos	Must
FR-004	Mantener corpus normativo versionado	Must
FR-005	Citar fuente y unidad en cada requisito	Must
FR-006	Motor de aplicabilidad condicional	Must
FR-007	Wizard de obligación DPD/DPO	Must
FR-008	Assessment adaptativo por dominio	Must
FR-009	Escala de madurez SPDP 0–3	Must
FR-010	Estado de conformidad separado	Must
FR-011	Nivel/calidad de evidencia	Must
FR-012	Cargar/enlazar evidencia con metadata	Must

ID	Requisito	Prioridad
FR-013	Crear brechas y plan de acción	Must
FR-014	Notificaciones de vencimiento	Must
FR-015	Dashboard ejecutivo	Must
FR-016	Generar informe diagnóstico	Must
FR-017	Crear y mantener RAT	Must
FR-018	Historial/versionado RAT	Must
FR-019	Matriz de bases de legitimación	Must
FR-020	Gestión de interés legítimo	Should
FR-021	Gestión de riesgos	Must
FR-022	EIPD conectada a riesgos/RAT	Must
FR-023	Privacy by Design gate	Should
FR-024	Registro de terceros/encargados	Must
FR-025	Due diligence de terceros	Should
FR-026	Gestión de cláusulas/contratos	Should
FR-027	Registro de transferencias	Must
FR-028	Evaluación de transferencias	Must
FR-029	Conservación/eliminación	Must
FR-030	Anonimización/seudonimización expediente	Should
FR-031	Catálogo de controles de seguridad	Must
FR-032	Mapeo a ISO/buenas prácticas	Could
FR-033	Registro y workflow de derechos	Must
FR-034	SLA/alertas de derechos	Must
FR-035	Registro de incidentes	Must
FR-036	Reloj/alertas de notificación	Must
FR-037	Matriz dinámica de destinatarios	Must
FR-038	Post-mortem y acciones de incidente	Should
FR-039	Motor MTGE	Must
FR-040	Casos directos gran escala	Must
FR-041	Obligaciones reforzadas gran escala	Must
FR-042	Inventario de IA	Should
FR-043	RAT/risks/audit para IA	Should
FR-044	Programa de auditoría	Must
FR-045	Checklist normativo versionado	Must
FR-046	Pruebas/muestreo de evidencia	Should
FR-047	Hallazgos y CAPA	Must
FR-048	Verificación independiente de cierre	Must
FR-049	Cockpit DPO	Must
FR-050	Bandeja de asesoría DPO	Must
FR-051	Opiniones/recomendaciones DPO	Must
FR-052	Bitácora de diligencia DPO	Must

ID	Requisito	Prioridad
FR-053	Conflicto/independencia DPO	Must
FR-054	Informe periódico DPO	Must
FR-055	Regulatory watch	Should
FR-056	Diff normativo e impacto	Should
FR-057	RAG normativo con citas	Should
FR-058	Consulta de documentos por tenant	Should
FR-059	Generación de borradores	Should
FR-060	Control de aprobación documental	Must
FR-061	Registro de capacitación	Should
FR-062	APIs e integraciones	Should
FR-063	Exportación PDF/DOCX/XLSX/CSV según objeto	Should
FR-064	Logs de auditoría inalterables/tamper-evident	Must
FR-065	DLP/PII guardrails en cargas	Must
FR-066	Métricas históricas/snapshots	Must
FR-067	Portafolio multi-cliente para consultor/DPO	Must
FR-068	Paquetes sectoriales configurables	Should

21. Casos de uso end-to-end

Caso	Flujo
CU-01 · Nuevo cliente	Consultor crea tenant → perfil de aplicabilidad → inventario inicial → assessment → evidencias → reporte → plan → aprobación de gerencia.
CU-02 · Implementación	Brecha crítica → paquete de trabajo → documento/control → evidencia → revisión → cierre → recalcule de madurez/conformidad/riesgo.
CU-03 · Nuevo proyecto/IA	Área registra iniciativa → privacy gate → RAT/IA → riesgo/EIPD → medidas → opinión DPO → aprobación responsable → monitoreo.
CU-04 · Derecho	Solicitud → validación → tareas → revisión DPO → respuesta aprobada → evidencia → métrica → cierre.
CU-05 · Vulneración	Alerta → triage → evaluación → reloj normativo → DPO asesora → responsable decide/notifica → post-mortem → CAPA.
CU-06 · Auditoría	Programa → snapshot normativo → pruebas → hallazgos → CAPA → verificación → informe → dashboard.
CU-07 · Cambio regulatorio	Fuente oficial nueva → captura/hash → validación → diff → mapeo de impacto → release → tareas/alertas por cliente → revalidación.
CU-08 · DPO mensual	Cockpit → revisar brechas/riesgos/derechos/incidentes/auditorías → emitir recomendaciones → reunión con gerencia → minuta y seguimiento.

22. Riesgos del producto y mitigaciones

Riesgo	Nivel	Consecuencia	Mitigación
Regla desactualizada	Alta	Decisión incorrecta	Regulatory watch + fecha de validación + bloqueo de regla no revisada + human approval.
Confundir guía con obligación	Alta	Sobre-cumplimiento o conclusión errónea	Clasificar fuerza/naturaleza de fuente y mostrarla en UI.
DPO convertido en implementador	Alta	Conflicto de interés / pérdida de independencia	Segregación de permisos, SoD y controles de asignación. [F06]
Promedio oculta brecha crítica	Alta	Falsa sensación de conformidad	Bloqueadores, requisitos críticos y risk view separados.
IA alucina normativa	Alta	Consejo no sustentado	RAG cerrado, citas obligatorias, "no source/no answer", aprobación humana.
Fuga entre clientes	Crítica	Vulneración de confidencialidad	Aislamiento tenant, pruebas, IAM, cifrado, logging y monitoreo.
Carga de datos sensibles innecesarios	Alta	Aumenta riesgo y obligaciones	DLP, redacción, minimización y política de evidencias.
Documentos divergentes	Media	Inconsistencia	Single source of truth + generación desde datos estructurados + versionado.
Automatización notifica incorrectamente	Alta	Riesgo legal/reputacional	Alertar/preparar; envío externo con aprobación y destinatarios versionados.
Uso indebido del score	Media	Marketing engañoso / mala decisión	No usar "certificado"; mostrar alcance, fecha, evidencia y limitaciones.

23. Criterios de aceptación de la solución

Criterio	Prueba de aceptación
Trazabilidad normativa	Seleccionar cualquier control y navegar hasta fuente, artículo/sección, versión y estado.
Reproducibilidad	Dos revisores con mismos inputs/evidencias obtienen la misma regla automática; diferencias humanas quedan justificadas.
No confusión de métricas	UI muestra por separado madurez, conformidad, evidencia y riesgo.
Separación DPO	El DPO no puede ser asignado como ejecutor de controles incompatibles ni aprobar su propia implementación.
Evidencia	No se puede marcar "verificado" sin evidencia o rationale autorizado.
Cambio normativo	Una nueva versión genera diff e identifica objetos/clientes potencialmente afectados.
Auditoría	Se conserva snapshot de criterios y evidencia revisada en la fecha de auditoría.
Seguridad	Pruebas demuestran que un tenant no puede consultar documentos/embeddings de otro.
IA	Toda respuesta normativa presenta fuentes; si no hay fuente suficiente, declara incertidumbre.
Reportes	Cada informe incluye alcance, fecha de corte, supuestos, limitaciones y fuentes.

24. Backlog de decisiones para la fase de discovery

Decisión	Pregunta de diseño
Producto	¿Uso interno SMARTCIDI, SaaS comercial o ambos?
Clientes	¿Pymes, corporativos, sector público, DPO externo o todos por etapas?
Stack	¿M365/Azure-first, SaaS propio o híbrido?
Custodia	¿Archivos dentro de plataforma o enlaces a DMS del cliente?
IA	¿Qué proveedor/modelo y qué garantías contractuales, retención y aislamiento ofrece?
Metodología	¿Qué preguntas SMARTCIDI se agregan al assessment SPDP y cómo se versionan?
Scoring	¿Qué requisitos serán bloqueadores y cuáles solo alimentan madurez?
Sectorización	¿Qué packs se desarrollan primero: salud, educación, financiero, comercio, RR.HH., tecnología/IA?
Firma	¿Qué documentos requieren firma, aprobación interna o solo versionado?
Integraciones	¿M365, Google, HighLevel, CRM, ticketing, SIEM, firma?
Operación normativa	¿Quién en SMARTCIDI valida y libera cambios regulatorios?
Seguridad	¿RTO/RPO, clasificación, retención y nivel de aseguramiento objetivo?

25. Bibliografía y registro de verificación

Criterio: se priorizaron fuentes oficiales y los documentos normativos proporcionados. La lista de resoluciones de la SPDP fue contrastada en su portal oficial el 11 de septiembre de 2026. El sistema propuesto debe conservar esta misma disciplina de verificación continua; ninguna bibliografía congelada puede garantizar por sí sola vigencia futura.

ID	Fuente	Uso en la guía	Ubicación
F01	Constitución de la República del Ecuador	Art. 66.19 y Art. 92, entre otros aplicables.	Archivo proporcionado: constitución Ecuador.pdf.
F02	Ley Orgánica de Protección de Datos Personales	Registro Oficial, Suplemento 459, 26-may-2021; considerar reformas posteriores.	Archivo proporcionado: ley_organica_de_proteccion_de_datos_personales (1).pdf.
F03	Reglamento General de la Ley Orgánica de Protección de Datos Personales	Decreto Ejecutivo 904; Registro Oficial, Tercer Suplemento 435, 13-nov-2023; estado vigente en gob.ec al corte.	https://www.gob.ec/ ; Registro Oficial No. 435.
F04	Guía de Gestión de Riesgos y Evaluación de Impacto del Tratamiento de Datos Personales – Versión 2	SPDP, versión final oficial disponible 2026. El Anexo (p. 75; p. 81 del PDF) confirma que el responsable puede definir las preguntas necesarias o no usar un cuestionario de referencia.	Portal oficial SPDP > Guías SPDP; PDF oficial versión 2 (2026).
F05	Guía de Protección de Datos Personales desde el Diseño y por Defecto	SPDP, 21-oct-2025. Cap. 3; numeral 3.1, Tabla 1, p. 17; numeral 3.2, pp. 18–19; numeral 3.3.1, Tabla 4, p. 20. Modelo recomendado, no obligatorio.	Portal oficial SPDP > Guías SPDP; PDF 40.02-Guía-de-Proteccion-de-Datos-desde-el-Disenio-y-po r-Defecto.pdf.

ID	Fuente	Uso en la guía	Ubicación
F06	Resolución SPDP-SPD-2025-0028-R — Reglamento del Delegado de Protección de Datos Personales	Funciones adicionales, independencia, conflictos, casos de designación y transitorias.	Archivo proporcionado: reglamento DPO.pdf; portal SPDP.
F07	Resolución SPDP-SPD-2025-0006-R	Obligación de incorporar cláusulas de protección de datos personales en contratos celebrados en Ecuador.	Archivo proporcionado; portal SPDP.
F08	Resolución SPDP-SPD-2025-0030-R	Reglamento para seudonimización, anonimización, bloqueo y eliminación.	Archivo proporcionado: reglamento_anonimizacion.pdf; portal SPDP.
F09	Resolución SPDP-SPD-2025-0041-R	Normativa general para aplicación del interés legítimo como base de legitimación.	Archivo proporcionado; portal SPDP.
F10	Resolución SPDP-SPD-2026-0004-R	Norma General de Transferencias o Comunicaciones Nacionales e Internacionales de Datos Personales.	https://spdp.gob.ec/resoluciones2/ ; PDF oficial SPDP.
F11	Resolución SPDP-SPD-2026-0005-R	Norma General sobre Tratamiento de Datos Personales a Gran Escala.	https://spdp.gob.ec/resoluciones2/ ; PDF oficial SPDP.
F12	Resolución SPDP-SPD-2026-0009-R	Norma General para la Garantía del Derecho de Protección de Datos Personales en el Uso de Sistemas de Inteligencia Artificial.	https://spdp.gob.ec/resoluciones2/ ; PDF oficial SPDP.
F13	Ley Orgánica para el Fortalecimiento de la Ciberseguridad	Registro Oficial, Quinto Suplemento No. 290, 22-may-2026; Art. 14 reforma el primer inciso del Art. 43 LOPDP.	Archivo proporcionado; Registro Oficial.
F14	Superintendencia de Protección de Datos Personales — Resoluciones emitidas	Índice oficial consultado/validado el 11-sep-2026; incluye resoluciones 2024–2026.	https://spdp.gob.ec/resoluciones2/
F15	ISO/IEC 27002:2022	Information security, cybersecurity and privacy protection — Information security controls. Buena práctica; no se trata como obligación LOPDP por sí sola.	Archivo proporcionado: ISO 27002-2022.pdf.
F16	Modelos para calcular el monto de las multas administrativas	SPDP. Útil para comprender factores de riesgo sancionatorio; el propio documento indica que los modelos son para uso de la SPDP, no para titulares/responsables/encargados.	Archivo proporcionado: Modelo-calculo-sanciones-administrativas-SPDP.pdf.
F17	European Commission / European Digital Innovation Hubs Network — Digital Maturity Assessment Tool (DMAT), FAQ	Benchmark metodológico no normativo: recomienda sesión guiada con el cliente y reporta una duración promedio aproximada de 1 hora para la evaluación de una pyme (FAQ 5.7, 5.9 y 5.18).	Portal oficial EDIH Network, “DMAT – Frequently Asked Questions (FAQ)”.

25.1 Fuentes normativas que la base de conocimiento debe monitorear

- Registro Oficial del Ecuador.
- Superintendencia de Protección de Datos Personales: resoluciones, guías, modelos, circulares, consultas, auditorías y servicios.
- Asamblea Nacional: leyes y reformas.
- Presidencia / portal gob.ec: reglamentos y decretos.
- Autoridades sectoriales cuando el tratamiento lo requiera (por ejemplo, salud, financiero, telecomunicaciones, seguros, educación, trabajo).

25.2 Observaciones de vigencia

La SPDP publica simultáneamente normas de diferentes años. El motor jurídico no debe inferir derogatoria o reemplazo solo por la fecha. Debe registrar relaciones de reforma/derogatoria expresas y, cuando exista solapamiento —por ejemplo, entre

normativa anterior y nueva normativa específica de transferencias—, exigir validación del responsable metodológico/legal antes de desactivar reglas históricas.

Las consultas absueltas por la SPDP pueden aportar contexto interpretativo, pero la propia autoridad advierte en determinadas respuestas que no tienen carácter vinculante y que su aplicación depende del caso concreto. La plataforma debe etiquetarlas como criterio orientativo, no como obligación autónoma.

26. Próximos pasos recomendados para SMARTCIDI

Paso	Decisión	Producto
1	Aprobar el modelo conceptual	Validar dominios, separación DPO, métricas y política de evidencia.
2	Convertir el assessment en catálogo	Preguntas, aplicabilidad, fuente, evidencia, score, criticidad y acciones sugeridas.
3	Construir matriz normativa maestra	LOPDP/RGLOPDP + resoluciones/guías 2024–2026 + normas conexas priorizadas.
4	Prototipar tres pantallas clave	Diagnóstico, tratamiento/RAT y DPO cockpit; probar con consultores reales.
5	Diseñar 10 reglas críticas	DPO, gran escala, EIPD, interés legítimo, transferencias, incidentes, IA, derechos, contratos, conservación.
6	Definir arquitectura y seguridad	Tenant, IAM, DMS, IA, logs, backups, integraciones y roles contractuales.
7	Piloto	Aplicar a 2–3 empresas de sectores diferentes usando solo información anonimizada/no productiva.
8	QA jurídico y de producto	Pruebas de reglas, usabilidad, segregación, reportes, exportación y actualización normativa.

RESULTADO ESPERADO

Una plataforma que permita a SMARTCIDI pasar de “checklists y documentos” a un sistema continuo de gobierno de privacidad: cada obligación aplicable es visible, cada control tiene dueño, cada conclusión tiene fuente, cada cierre tiene evidencia y cada cambio deja trazabilidad.

Nota profesional

Este documento es una versión borrador de apoyo consultivo y debe ser revisado y adaptado por el consultor responsable de SMARTCIDI y, cuando corresponda, por un profesional legal competente antes de su entrega o implementación final.